

JUNIO 2026

THE BRIDGE
BOOTCAMPS



ANÁLISIS Y GESTIÓN DE RIESGOS - MAGERIT

Versión	Fecha	Estado	Clasificación
1.0	Junio 2026	Aprobado	Interno

01 Propósito y alcance

Este documento presenta el análisis de riesgos del proyecto realizado mediante la metodología MAGERIT. Su objetivo es identificar los activos críticos de la aplicación, evaluar las amenazas que pueden afectarles y determinar el nivel de riesgo asociado a cada una de ellas, con el fin de definir las medidas de protección más adecuadas.

El análisis cubre los activos principales de la plataforma en desarrollo: la base de datos de usuarios, el sistema de autenticación, la API Backend, el sistema de copias de seguridad y el código fuente. Es de aplicación al equipo de Ciberseguridad y sirve como referencia para la toma de decisiones de seguridad en todas las etapas del proyecto.

Un riesgo no identificado no se puede mitigar. Este documento existe para que ninguna amenaza relevante quede fuera del radar del equipo.

Equipos a los que aplica

CIBERSEGURIDAD

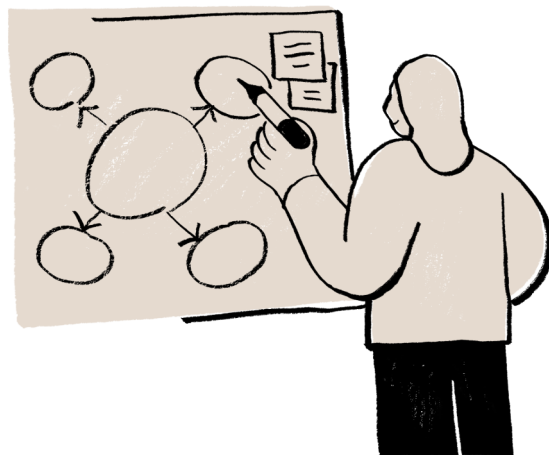
02 ¿Qué es MAGERIT?

MAGERIT (Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información) es la metodología oficial de análisis de riesgos publicada por el Consejo Superior de Administración Electrónica del Gobierno de España. Su versión vigente es la 3.0, publicada en 2012.

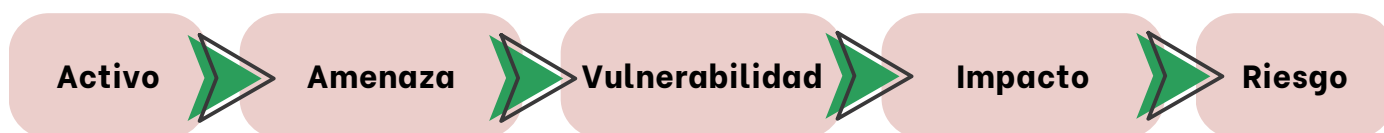
Fue diseñada para dar respuesta a una necesidad concreta: que las organizaciones que gestionan información puedan conocer con rigor cuánto riesgo asumen, qué puede pasar si ese riesgo se materializa y qué deben hacer para reducirlo a un nivel aceptable.

¿Por qué MAGERIT y no otra metodología?

MAGERIT es la metodología de referencia del Esquema Nacional de Seguridad (ENS), de obligado cumplimiento para sistemas que operan en el ámbito de la Administración Pública española o que prestan servicios a ella. Además, es la más extendida entre proveedores tecnológicos del sector público español y su estructura conceptual es especialmente didáctica, lo que la hace adecuada para equipos sin experiencia previa en análisis de riesgos.



Su lógica es directa y trazable:



El proceso MAGERIT en 7 pasos

Paso	Tipo	Etapas
1	Identificar y valorar activos	¿Qué tenemos y cuánto vale?
2	Identificar amenazas	¿Qué puede salir mal?
3	Estimar probabilidad	¿Con qué frecuencia ocurre?
4	Estimar degradación	¿Cuánto daño hace si ocurre?
5	Calcular impacto	¿Qué daño real produce al negocio?
6	Calcular riesgo	¿Cómo de grave es en conjunto?
7	Tratamiento del riesgo	¿Qué hacemos con él?

MAGERIT no elimina los riesgos. Los hace visibles para que la organización pueda decidir, con criterio y de forma documentada, qué hacer con cada uno de ellos.

Las cinco dimensiones de seguridad - DAICT

MAGERIT valora cada activo en cinco dimensiones. Juntas forman el acrónimo DAICT:

- **D - Disponibilidad:** el activo está accesible cuando se necesita
- **A - Autenticidad:** garantiza que algo es quien dice ser
- **I - Integridad:** los datos no han sido modificados sin autorización
- **C - Confidencialidad:** solo acceden quienes están autorizados
- **T - Trazabilidad:** se puede saber quién hizo qué y cuándo

03 El análisis paso a paso

FASE 1: Identificar activos

Antes de comenzar el análisis de riesgos mediante la metodología MAGERIT, es necesario identificar cuáles son los activos más importantes de la aplicación y qué impacto tendría para el negocio que dichos activos se vieran comprometidos.

La aplicación que se está desarrollando tiene como objetivo ayudar a personas extranjeras a disfrutar de una experiencia más auténtica durante su estancia en el País Vasco, ofreciéndoles recomendaciones personalizadas de actividades, ocio, gastronomía y lugares de interés. Para poder proporcionar estos servicios, la plataforma deberá gestionar información de los usuarios, sus preferencias y las diferentes opciones de ocio disponibles.

A partir de esta funcionalidad, se pueden identificar varios activos críticos. Entre ellos destacan la base de datos de usuarios, el sistema de autenticación, la API encargada de procesar las peticiones de la aplicación, la base de datos de actividades y establecimientos recomendados, así como las copias de seguridad y el propio código fuente del proyecto.

Una vez identificados los activos, el siguiente paso consiste en analizar las amenazas que podrían afectarles. En el caso de una aplicación web de estas características, algunas de las amenazas más relevantes serían el robo de credenciales de acceso, el acceso no autorizado a información de usuarios, la pérdida de datos por errores humanos o fallos técnicos, los ataques de denegación de servicio que impidan el uso normal de la plataforma o la explotación de vulnerabilidades presentes en el código de la aplicación.

Por ejemplo, si un atacante consiguiera acceder a la base de datos de usuarios, podrían verse comprometidos datos personales como nombres, direcciones de correo electrónico o preferencias de los usuarios. Del mismo modo, un error accidental por parte de un administrador podría provocar la pérdida de información importante si no existieran mecanismos adecuados de respaldo y recuperación.

Este análisis inicial permite comprender qué elementos son más importantes para el funcionamiento de la aplicación y qué riesgos deben mitigarse durante el desarrollo. Además, sirve como base para justificar la implantación de medidas de seguridad como el uso de autenticación segura, cifrado de comunicaciones mediante HTTPS, copias de seguridad periódicas, análisis estático del código con SonarQube y controles de acceso adecuados.

De esta forma, la metodología MAGERIT no solo permite identificar los riesgos existentes, sino también priorizar las medidas de protección necesarias para reducir su impacto y garantizar la seguridad de la aplicación a lo largo de todo su ciclo de vida.

Activo	D	A	I	C	T
Base de datos de usuarios	10	10	10	10	8
Sistemas de autenticación	10	10	9	9	8
API Backend	9	9	9	7	7
Backups	10	9	10	8	7
Código fuente	8	9	9	8	6

Base de datos de usuarios

Contendrá información como correos electrónicos, preferencias, idioma, historial de uso y cualquier dato personal almacenado por la aplicación.

Dimensión	Valor	Justificación
Disponibilidad	10	Si la base de datos deja de estar disponible, la aplicación no podrá funcionar correctamente y los usuarios no podrán acceder a sus datos
Autenticidad	10	Es fundamental garantizar que los datos corresponden realmente a cada usuario que se loguea y que no han sido modificados por terceros
Integridad	10	La modificación no autorizada de los datos podría afectar a las recomendaciones ofrecidas o provocar errores en la plataforma
Confidencialidad	10	Contiene datos personales de los usuarios y estos deben protegerse según la normativa de protección de datos
Trazabilidad	8	Es importante saber quién accede o modifica la información para detectar incidentes y realizar auditorías

Sistema de Autenticación

Es el mecanismo que permite registrar usuarios, iniciar sesión y gestionar las sesiones activas.

Dimensión	Valor	Justificación
Disponibilidad	10	Si el sistema de autenticación falla, ningún usuario podrá acceder a la plataforma
Autenticidad	10	Garantizar que cada usuario es quien dice ser
Integridad	9	Cualquier alteración del sistema podría permitir accesos indebidos o fallos de seguridad
Confidencialidad	9	Gestiona credenciales y datos sensibles relacionados con la identidad de los usuarios
Trazabilidad	8	Es necesario registrar accesos, intentos fallidos y cambios relacionados con la autenticación.

API Backend

Es el componente encargado de procesar las peticiones entre el frontend y la base de datos.

Dimensión	Valor	Justificación
Disponibilidad	9	La API es fundamental para el funcionamiento de la aplicación y debe estar operativa en todo momento
Autenticidad	9	Debe verificar correctamente la identidad de los usuarios y sistemas que realizan operaciones
Integridad	9	La información intercambiada debe mantenerse libre de modificaciones no autorizadas
Confidencialidad	7	Aunque gran parte de la información viaja cifrada, la API procesa datos sensibles de usuarios
Trazabilidad	7	Resulta necesario disponer de registros que identifiquen errores o actividades sospechosas

Sistema de copias de seguridad (Backups)

Permite recuperar la información en caso de pérdida, corrupción o incidente de seguridad.

Dimensión	Valor	Justificación
Disponibilidad	10	Los backups deben estar accesibles cuando sea necesario recuperar la información
Autenticidad	9	Debe verificarse que las copias son legítimas y que no han sido sustituidas por versiones alteradas.
Integridad	10	Una copia de seguridad corrupta o modificada pierde completamente su utilidad
Confidencialidad	8	Las copias contienen información sensible que debe protegerse frente a accesos no autorizados
Trazabilidad	7	Es importante registrar cuando se realizan las copias y quien accede a ellas

Código Fuente y repositorio GitHub

Incluye todo el código desarrollado por el equipo y la configuración de la aplicación.

Dimensión	Valor	Justificación
Disponibilidad	8	La pérdida del repositorio dificultará el mantenimiento y evolución del proyecto
Autenticidad	9	Debe garantizarse que el código proviene de desarrolladores autorizados
Integridad	10	La modificación no autorizada del código podría introducir vulnerabilidades o comportamientos maliciosos
Confidencialidad	8	El código puede contener información sobre la arquitectura interna o configuraciones sensibles
Trazabilidad	9	Git proporciona un historial completo de cambios que resulta fundamental para el desarrollo seguro

Conclusión

Tras realizar la valoración DAICT, se observa que los activos más críticos para la organización son la base de datos de usuarios, el sistema de autenticación y el sistema de copias de seguridad, ya que concentran los valores más elevados en disponibilidad, integridad y confidencialidad. La protección de estos activos deberá constituir una prioridad durante el diseño e implantación de los controles de seguridad del proyecto. Asimismo, el análisis pone de manifiesto la importancia de garantizar la integridad del código fuente y la disponibilidad de la API Backend, elementos fundamentales para asegurar la continuidad del servicio y la confianza de los usuarios.



FASE 2 - Identificar las amenazas

Vamos a meter tres amenazas por cada activo que hemos encontrado en el primer paso.



Base de datos de usuarios

Activo 1 - 3 amenazas identificadas

[A] Ataque deliberado

Acceso no autorizado

Un atacante consigue acceder a la base de datos sin permiso.

CONSECUENCIAS

- Robo de datos personales
- Pérdida de privacidad
- Incumplimiento del RGPD

[A] Código dañino

Ransomware

Un malware cifra toda la base de datos volviéndola inaccesible.

CONSECUENCIAS

- Aplicación fuera de servicio
- Pérdida temporal de información
- Costes de recuperación

[E] Error no intencionado

Error humano

Un administrador elimina información de la base de datos por error.

CONSECUENCIAS

- Pérdida de datos
- Interrupción del servicio



Sistema de autentificacion

Activo 2 - 3 amenazas identificadas

[A] Acceso no autorizado

Fuerza bruta

Intentos masivos de adivinar contraseñas

CONSECUENCIAS

- Compromiso de cuentas
- Acceso indebido

[A] Uso de credenciales de otro usuario

Credential Stuffing

Uso de credenciales filtradas previamente

CONSECUENCIAS

- Robo de cuentas
- Suplantacion de identidad

[A] Ingenieria social

Phishing

Robo de credenciales mediante engaño

CONSECUENCIAS

- Acceso a cuentas legítimas
- Exposicion de informacion personal



API Backend

Activo 3 - 3 amenazas identificadas

[A] Modificación de información

Inyección SQL

Manipulación de consultas mediante entradas maliciosas

CONSECUENCIAS

- Robo de información
- Modificación de datos

[A] Denegación de servicios

Denegación de servicio

Sobrecarga de peticiones

CONSECUENCIAS

- Aplicación inaccesible

[A] Abuso de privilegios

Acceso indebido a la API

Un usuario accede a recursos que no le corresponden

CONSECUENCIAS

- Exposición de datos
- Manipulación de información



Backups

Activo 4 - 3 amenazas identificadas

[I] Fallo de almacenamiento

Perdida de copias

Las copias dejan de estar disponibles

CONSECUENCIAS

- Imposibilidad de recuperación

[A] Divulgación de información

Acceso no autorizado

Un atacante accede a las copias

CONSECUENCIAS

- Exposición de datos sensibles

[E] Error no intencionado

Corrupción de backups

Las copias existen pero son inutilizables

CONSECUENCIAS

- Recuperación imposible



Código fuente

Activo 5 – 3 amenazas identificadas

[A] Divulgación de información



Robo de código

Acceso no autorizado al repositorio

CONSECUENCIAS

- Exposición de arquitectura
- Pérdida de propiedad intelectual

[P] Error o acción intencionada del personal



Introducción de código malicioso

Un desarrollador o atacante modifica el código

CONSECUENCIAS

- Vulnerabilidades
- Puertas traseras

[E] Error no intencionado



Borrado accidental

El repositorio se elimina o daña

CONSECUENCIAS

- Pérdida de trabajo
- Retrasos en el proyecto

FASE 3 - Estimar la probabilidad

Pregunta: ¿Con qué frecuencia es razonable que esto ocurra?

Activo	Amenaza	Probabilidad
Base de Datos	Acceso no autorizado	Media (3)
Base de Datos	Ransomware	Baja (2)
Base de Datos	Error humano	Alta (4)
Autenticación	Fuerza bruta	Alta (4)
Autenticación	Credential Stuffing	Alta (4)
Autenticación	Phishing	Alta (4)
API	SQL injection	Media (3)
API	DDos	Baja (2)
API	Broken Access Control	Alta (4)
Backups	Pérdida de copias	Media (3)
Backups	Acceso indebido	Media (3)
Backups	Corrupción	Baja (2)
Código Fuente	Robo de código	Baja (2)
Código Fuente	Código vulnerable	Alta (4)
Código Fuente	Borrado accidental	Media (3)

Tras identificar los activos y las amenazas asociadas, se ha realizado una estimación cualitativa de la probabilidad de ocurrencia de cada riesgo siguiendo los criterios de MAGERIT. Para ello se ha tenido en cuenta la naturaleza de la aplicación, su exposición a Internet, la frecuencia con la que suelen producirse este tipo de incidentes y las medidas de seguridad previstas durante el desarrollo. Como resultado, amenazas como el phishing, la fuerza bruta o los errores humanos presentan una probabilidad más elevada que eventos menos frecuentes como ataques de ransomware o denegaciones de servicio.

FASE 4 - Estimar la degradación

Si ocurre, ¿cuánto daño hace al activo?

1. Base de datos - Acceso no autorizado

Disponibilidad	Autenticidad	Integridad	Confidencialidad	Trazabilidad
20%	80%	80%	100%	60%

Justificación:

- La base de datos sigue funcionando
- El atacante puede modificar datos
- La confidencialidad queda totalmente comprometida

2. Base de datos - Error humano

Disponibilidad	Autenticidad	Integridad	Confidencialidad	Trazabilidad
70%	10%	90%	10%	30%

Justificación:

- Puede borrarse información
- La integridad es la más afectada
- La confidencialidad apenas cambia

3. Sistema de autenticación - Credential Stuffing

Disponibilidad	Autenticidad	Integridad	Confidencialidad	Trazabilidad
10%	100%	60%	80%	50%

Justificación:

- El principal daño es que deja de existir confianza en la identidad de usuarios.

4. Sistema de autenticación – Phishing

Disponibilidad	Autenticidad	Integridad	Confidencialidad	Trazabilidad
10%	100%	50%	80%	40%

5. API – SQL injection

Disponibilidad	Autenticidad	Integridad	Confidencialidad	Trazabilidad
40%	60%	100%	100%	60%

Justificación:

- Una SQL injection puede: Leer datos, modificar datos y borrar datos

6. API – Broken Access Control

Disponibilidad	Autenticidad	Integridad	Confidencialidad	Trazabilidad
20%	90%	70%	100%	50%

7. Backups – Pérdida de copias

Disponibilidad	Autenticidad	Integridad	Confidencialidad	Trazabilidad
100%	10%	80%	10%	20%

Justificación:

- Si necesitas restaurar y no puedes. El impacto en disponibilidad es enorme

8. Código Fuente – Introducción de Código Vulnerable

Disponibilidad	Autenticidad	Integridad	Confidencialidad	Trazabilidad
30%	60%	100%	40%	60%

FASE 5 - Calcular el impacto

Si esta amenaza ocurre, ¿qué daño real produce al negocio?

ACTIVO	AMENAZA	IMPACTO
Base de Datos	Acceso no autorizado	Muy Alto (5)
Base de Datos	Error humano	Alto (4)
Autenticación	Credential Stuffing	Muy Alto (5)
Autenticación	Phishing	Alto (4)
API	SQL Injection	Muy Alto (5)
API	Broken Access Control	Muy Alto (5)
Backups	Pérdida de Copias	Muy Alto (5)
Código Fuente	Código Vulnerable	Alto (4)

Una vez estimada la degradación de los activos, se ha procedido a evaluar el impacto que tendría la materialización de cada amenaza sobre el proyecto. Para ello se ha considerado el daño potencial sobre la disponibilidad del servicio, la confidencialidad de los datos, la integridad de la información y las posibles consecuencias operativas y reputacionales para la organización. Los resultados muestran que los activos más críticos son la base de datos de usuarios, el sistema de autenticación, la API y las copias de seguridad, ya que un incidente sobre ellos tendría un impacto alto o muy alto sobre el funcionamiento de la aplicación.

FASE 6 - Calcular el riesgo**1. Base de datos - Acceso no autorizado**

ELEMENTO	VALOR
Probabilidad	Medio
Impacto	Muy Alto
Riesgo	Alto

Justificación:

- La exposición de datos personales tendría consecuencias legales y reputacionales importantes para la aplicación.

2. Base de datos - Error humano

ELEMENTO	VALOR
Probabilidad	Alto
Impacto	Alto
Riesgo	Alto

Justificación:

- Los errores humanos son frecuentes y pueden provocar pérdida de información o interrupciones del servicio.

3. Sistema de autenticación - Credential Stuffing

ELEMENTO	VALOR
Probabilidad	Alto
Impacto	Muy Alto
Riesgo	Crítico

Justificación:

- El robo de cuentas compromete directamente la confianza en la plataforma

4. Sistema de autenticación – Phishing

ELEMENTO	VALOR
Probabilidad	Alto
Impacto	Alto
Riesgo	Alto

Justificación:

- Permite a un atacante obtener credenciales legítimas y acceder a información privada

5. API – SQL injection

ELEMENTO	VALOR
Probabilidad	Media
Impacto	Muy alto
Riesgo	Alto

Justificación:

- Una inyección SQL podría permitir el acceso o modificación de información sensible

6. API – Broken Access Control

ELEMENTO	VALOR
Probabilidad	Alta
Impacto	Muy Alta
Riesgo	Crítica

Justificación:

- Es una de las vulnerabilidades más frecuentes según OWASP y podría permitir que un usuario accediera a información de otros usuarios

7. Backups – Pérdida de copias

ELEMENTO	VALOR
Probabilidad	Media
Impacto	Muy alto
Riesgo	Alto

Justificación:

- La pérdida de las copias impediría recuperar el servicio ante un incidente grave

8. Código Fuente – Introducción de Código Vulnerable

ELEMENTO	VALOR
Probabilidad	Alto
Impacto	Alto
Riesgo	Alto

Justificación:

- Puede introducir vulnerabilidades explotables en producción

FASE 7 - Tratamiento del riesgo

Riesgo	Nivel Inicial	Tratamiento	Control principal	Riesgo Residual
Credential Stuffing	Crítico	Mitigar	MFA + Bloque de intentos	Medio
Broken Access Control	Crítico	Mitigar	Roles y permisos	Medio
SQL Injection	Alto	Mitigar	Consultas parametrizadas	Bajo
Acceso no Autorizado BBDD	Alto	Mitigar	Cifrado y control de accesos	Medio
Error Humano	Alto	Mitigar	Procedimientos y backups	Medio
Perdida de Backups	Alto	Mitigar	Estrategia 3, 2, 1	Bajo
Phishing	Alto	Mitigar	MFA y alertas	Medio
Código vulnerable	Alto	Mitigar	SonarQube y revisión	Bajo

Una vez identificados y evaluados los riesgos asociados a los principales activos del proyecto, se han definido diferentes medidas de tratamiento con el objetivo de reducir su probabilidad de ocurrencia y minimizar su impacto.

La estrategia adoptada se basa principalmente en la mitigación mediante controles técnicos y organizativos, tales como la autenticación multifactor (MFA), el análisis estático de código con SonarQube, la aplicación de controles de acceso, la realización de copias de seguridad periódicas y la adopción de buenas prácticas de desarrollo seguro.

Tras la implantación de estas medidas, los riesgos no desaparecen completamente, sino que se reducen hasta niveles considerados aceptables para el proyecto, constituyendo el denominado riesgo residual.

